

Siber Güvenlik Tehditleri, Tespiti ve Savunma Stratejileri Üzerine Kapsamlı Bilgilendirme

Yönetici Özeti

Bu bilgilendirme belgesi, modern siber güvenlik tehditlerinin karmaşık yapısını, bu tehditlere karşı kullanılan savunma teknolojilerini ve Güvenlik Operasyonları Merkezi (SOC) operasyonlarının temel dinamiklerini bütünsel bir yaklaşımla sentezlemektedir. Analizler, siber saldırıların artık tekil olaylar olmaktan çıkıp, Siber "Kill Chain" ve MITRE ATT&CK gibi çerçevelerle tanımlanan, keşiften veri sızdırmaya kadar uzanan çok aşamalı kampanyalara dönüştüğünü ortaya koymaktadır. Saldırganlar, ortalama (phishing) gibi sosyal mühendislik taktikleri, internete açık bırakılmış RDP ve SSH servisleri veya tedarik zinciri ihlalleri gibi çeşitli vektörler aracılığıyla ilk erişimi sağlamaktadır. Etkili bir savunma stratejisinin temel taşı, "savunamayacağınızı göremezsiniz" ilkesiyle özetlenen ağ görünürlüğüdür. Bu görünürlük, hem uç noktalardan (host-merkezli) hem de ağ cihazlarından (ağ-merkezli) toplanan logların SIEM (Güvenlik Bilgi ve Olay Yönetimi) gibi platformlarda merkezileştirilmesi ve korelasyonu ile sağlanır. EDR (Uç Nokta Tespiti ve Müdahale) çözümleri, geleneksel antivirüslerin ötesinde, uç noktalardaki davranışsal anomalileri tespit ederek derinlemesine koruma sunarken; Saldırı Tespit Sistemleri (IDS), ağ trafiğindeki bilinen ve bilinmeyen tehditleri belirler. Saldırganların giderek artan bir şekilde PowerShell, WMIC ve certutil gibi meşru sistem araçlarını kullandığı "Living-Off-the-Land" (LOL) saldırıları, tespiti zorlaştırmakta ve komut satırı düzeyinde proaktif izlemenin önemini vurgulamaktadır. SOC operasyonlarının verimliliği, L1 analistlerinin uyarıları etkili bir şekilde önceliklendirmesi, "Çalışma Kitapları" (Workbooks) kullanarak standartlaştırılmış analizler yapması ve gerçek tehditleri (True Positives) L2 ekiplerine zamanında yükseltmesine bağlıdır. Siber Tehdit İstihbaratı (CTI), ham verileri eyleme geçirilebilir içgörülere dönüştürerek, SOC'lerin reaktif bir duruştan proaktif ve öngörülü bir savunma modeline geçişini sağlar. Nihayetinde, katmanlı bir savunma yaklaşımı; teknik kontroller (SPF, DKIM, DMARC, WAF), platforma özgü sıkılaştırmalar (Windows, Linux, Web Uygulamaları) ve insan faktörünü (kullanıcı eğitimi) bir araya getirerek modern siber tehditlere karşı dayanıklılığı artırır.

Bölüm 1: Stratejik Çerçeveler ve Temel Kavramlar

Modern siber savunma, saldırıların davranışlarını, kullandıkları araçları ve motivasyonlarını anlamayı gerektirir. Bu amaçla geliştirilen stratejik çerçeveler ve kavramlar, savunma ekiplerine ortak bir dil ve sistematik bir yaklaşım sunar.

Siber "Kill Chain" Modeli

Askeri terminolojiden uyarlanan "Kill Chain" (öldürme zinciri) modeli, bir siber saldırının başlangıcından nihai hedefine ulaşana kadar izlediği aşamalı yapıyı tanımlar. Bu aşamaları anlamak, savunmacıların saldırıyı nerede ve nasıl durdurabileceğine dair stratejik avantaj sağlar.

- Keşif (Reconnaissance):** Saldırganın hedef hakkında pasif olarak bilgi topladığı (e-posta adresleri, altyapı detayları) araştırma ve planlama safhasıdır.
- Silahlandırma (Weaponization):** Saldırıda kullanılacak kötü amaçlı içeriğin (payload), bir exploit ile birleştirilerek oluşturulduğu aşamadır.

3. **Teslimat (Delivery):** Silah haline getirilmiş yükün hedefe iletilmesidir (örneğin, ortalama e-postası).
4. **Sömürü (Exploitation):** Kötü amaçlı kodun hedef sistemdeki bir zafiyetten faydalanarak yürütüldüğü andır.
5. **Kurulum (Installation):** Saldırganın, gelecekteki erişimini güvence altına almak için sisteme kalıcı bir arka kapı (backdoor) kurmasıdır.
6. **Komuta ve Kontrol (C2 - Command & Control):** Ele geçirilen sistem ile saldırgan arasında bir iletişim kanalı kurulmasıdır.
7. **Eylem (Action):** Saldırganın nihai hedefine (veri sızdırma, sistemi sabote etme vb.) ulaştığı son aşamadır.

MITRE Tarafından Sağlanan Temel Güvenlik Kaynakları

MITRE, siber güvenlik topluluğuna paha biçilmez kaynaklar sunan, kar amacı gütmeyen bir kuruluştur. Bu kaynaklar, tehditleri anlamak ve savunma stratejileri geliştirmek için standartlaşmış bir temel oluşturur.

- **MITRE ATT&CK®:** Gerçek dünya gözlemlerine dayanan, saldırgan taktik ve tekniklerinin küresel olarak erişilebilir bir bilgi tabanıdır. SOC analistleri, gözlemledikleri şüpheli faaliyetleri ATT&CK matrisindeki belirli tekniklerle (örneğin, T1566.001 - Spearphishing Attachment) eşleştirerek olaylara ortak bir dil ve bağlam kazandırır.
- **CVE (Common Vulnerabilities and Exposures):** Bilinen yazılım zafiyetlerine atanan benzersiz tanımlayıcılardır. Güvenlik uzmanları, bir sistemin hangi zafiyetlere karşı savunmasız olduğunu belirlemek için CVE listesini kullanır.
- **D3FEND:** ATT&CK çerçevesinin savunma tarafındaki karşılığıdır. Belirli saldırı tekniklerine karşı kullanılabilecek savunma yöntemlerini ve teknolojilerini kataloglar.

Siber Tehdit İstihbaratı (CTI) Yaşam Döngüsü

Siber Tehdit İstihbaratı (CTI), ham verileri (loglar, uyarılar) bir kuruluşun tehditlere karşı proaktif savunma yapmasını sağlayan, bağlamsal ve eyleme geçirilebilir içgörülere dönüştürme sürecidir. Bu süreç, altı aşamalı bir yaşam döngüsünü takip eder:

1. **Yönlendirme (Direction):** İstihbarat toplama hedeflerinin belirlenmesi (Örn: "PostgreSQL veritabanlarımızı hedef alan aktif tehditler nelerdir?").
2. **Toplama (Collection):** Açık kaynak, ticari ve dahili kaynaklardan ham verilerin toplanması.
3. **İşleme (Processing):** Toplanan verilerin standart bir formata dönüştürülmesi (normalizasyon).
4. **Analiz (Analysis):** İşlenmiş bilginin kuruluşun özel riskleriyle ilişkilendirilerek değerlendirilmesi ve "Peki ne olmuş?" sorusunun yanıtlanması.
5. **Yayma (Dissemination):** Analiz edilen istihbaratın ilgili paydaşlara (güvenlik duvarı ekibi, yönetim vb.) uygun formatlarda sunulması.
6. **Geri Bildirim (Feedback):** Uygulanan kontrollerin etkinliğinin ölçülmesi ve sürecin iyileştirilmesi.

Saldırı Göstergeleri (IoC) ve Savunmadaki Rolü

Saldırı Göstergeleri (Indicators of Compromise - IoC), bir sistemde veya ağda potansiyel bir ihlali işaret eden dijital izlerdir. | Gösterge Türü | Açıklama | Savunma Değeri || ----- | ----- | ----- || **Hash Değerleri** | Bir dosyanın (kötü amaçlı yazılım gibi) benzersiz dijital parmak izi

(MD5, SHA256). | Yüksek. Saldırgan dosyayı değiştirmedikçe, bu hash değeri ile tespit edilebilir. || **IP Adresleri** | Saldırganın C2 sunucusu veya saldırı kaynağı olarak kullandığı adres. | Düşük/Orta. Saldırganlar IP adreslerini kolayca değiştirebilir veya proxy'ler kullanabilir. || **Alan Adları** | Saldırgan tarafından ortalama veya C2 iletişimi için kullanılan alan adları (örn: malicious-updates.net). | Orta. Bir alan adını engellemek, o alan adıyla ilişkili tüm IP'leri engeller ancak saldırgan yeni bir alan adı kaydedebilir. || **Dosya Yolları/Adları** | Saldırganların kullandığı belirli dosya yolları (örn: C:\Windows\Temp) veya adlandırma kalıpları (örn: invoice.pdf.exe). | Orta. Davranışsal kalıpları tespit etmek için faydalıdır. |

Bölüm 2: Saldırgan Taktikleri, Teknikleri ve Prosedürleri (TTP'ler)

Saldırganların hedeflerine ulaşmak için kullandığı yöntemler, ilk erişimden kalıcılığa kadar geniş bir yelpazeyi kapsar.

İlk Erişim (Initial Access)

Saldırganların bir ağa sızmak için kullandığı başlangıç noktalarıdır.

- **Oltalama (Phishing):** En yaygın yöntemdir. Güvenilir bir kurumdan geliyormuş gibi görünen e-postalarla kurbanların kötü amaçlı ekleri açması veya sahte bağlantılara tıklaması hedeflenir. Türleri arasında belirli kişileri hedef alan **Spear Phishing** ve üst düzey yöneticileri hedef alan **Whaling** bulunur.
- **İnternete Açık Servislerin Sömürülmesi:**
- **Uzak Masaüstü Protokolü (RDP):** Zayıf parolalarla internete açık bırakılan RDP servisleri, fidye yazılımı grupları için birincil giriş kapısıdır. Bu risk o kadar yaygındır ki, RDP "Fidye Yazılımı Dağıtım Protokolü" (Ransomware Deployment Protocol) olarak anılmaktadır. Censys verilerine göre 5 milyondan fazla RDP makinesi internetten erişilebilir durumdadır.
- **SSH (Secure Shell):** Özellikle Linux sunucularda, zayıf parolalara yönelik kaba kuvvet (brute-force) saldırıları veya çalınmış SSH özel anahtarları ile sisteme sızılır.
- **Tedarik Zinciri İhlalleri:** Saldırganlar, meşru bir yazılımı ele geçirerek kötü amaçlı güncellemeler aracılığıyla tüm kullanıcı tabanına yayılırlar.

Keşif ve Yanal Hareket (Discovery & Lateral Movement)

Saldırganlar sisteme girdikten sonra, ağ yapısını, kullanıcıları ve değerli varlıkları anlamak için keşif yaparlar.

- **"Living-Off-the-Land" (LOL) Saldırıları:** Saldırganlar, tespit edilmekten kaçınmak için sisteme özel araçlar yüklemek yerine, hedef sistemde zaten mevcut olan meşru ve güvenilir araçları kullanırlar. Bu durum, kötü amaçlı aktivitenin normal yönetim faaliyetlerinden ayırt edilmesini zorlaştırır.
- **Yaygın Windows Araçları:** PowerShell, WMIC, certutil, mshta, rundll32, schtasks.
- **Yaygın Linux Araçları:** wget, curl, bash, ssh.
- **Ağ Keşfi:** Saldırganlar, ağdaki diğer aktif sistemleri ve açık portları bulmak için yatay (aynı portu birçok IP'de tarama) ve dikey (tek IP'de birçok portu tarama) taramalar gerçekleştirir.
- **Süreç Ağacı Analizi:** Bir saldırının başlangıcını ve sonraki adımlarını anlamak için en etkili yöntemdir. Şüpheli bir komuttan geriye doğru gidilerek olayı başlatan kök süreç (örn: bir web sunucusu, bir SSH oturumu) bulunur.

Kötü Amaçlı Yazılım ve Analiz Teknikleri

Kötü amaçlı yazılım (malware), saldırganların hedeflerini gerçekleştirmek için kullandığı temel araçtır.

- **Analiz Yöntemleri:**
- **Statik Analiz:** Kötü amaçlı yazılımı çalıştırmadan, içerdiği metin dizeleri (strings), PE başlığı ve kod yapısı gibi özelliklerini incelemektir.
- **Dinamik Analiz:** Kötü amaçlı yazılımı kontrollü bir sanal ortamda (sandbox) çalıştırarak ağ bağlantıları, dosya sistemi değişiklikleri ve kayıt defteri modifikasyonları gibi davranışlarını gözlemlemektir.
- **Analiz Karşıtı Teknikler:** Salırganlar, analizi zorlaştırmak için çeşitli yöntemler kullanır.
- **Paketleme ve Gizleme (Packing & Obfuscation):** Kodun içeriğini sıkıştırarak veya şifreleyerek statik analizi engeller.
- **Sandbox'tan Kaçınma:** Sanal makine ortamını tespit etme, uzun uyku çağrıları yapma veya fare hareketi gibi kullanıcı etkileşimi bekleme gibi tekniklerle dinamik analizden kaçınır.

Veri Sızdırma (Data Exfiltration)

Hassas verilerin ağ dışına yetkisiz olarak aktarılmasıdır. Bu, genellikle tespiti zorlaştırmak için meşru protokollere gizlenir.

- **DNS Tünelleme:** Veriler, DNS sorgularının subdomain kısımlarına kodlanarak gönderilir. Uzun ve anlamsız sorgu adları önemli bir göstergedir.
- **ICMP Tünelleme:** Veriler, normalde küçük olan ICMP (Ping) paketlerinin veri alanına gizlenir. Anormal derecede büyük ICMP paketleri şüphe uyandırmalıdır.
- **HTTP/HTTPS Üzerinden Sızdırma:** Veriler, büyük HTTP POST istekleri ile normal web trafiği arasına gizlenerek gönderilir.

Kalıcılık (Persistence)

Salırganların, sistem yeniden başlatılsa bile erişimlerini sürdürmek için kullandıkları yöntemlerdir.

- **Windows:** Zamanlanmış Görevler (schtasks.exe) en yaygın yöntemdir. Ayrıca Başlangıç klasörüne veya kayıt defterindeki "Run" anahtarlarına girdi eklemek de kullanılır.
- **Linux:** Cron job'ları (zamanlanmış görevler), Systemd servisleri oluşturmak, yeni kullanıcı hesapları eklemek veya mevcut kullanıcıların ~/.ssh/authorized_keys dosyasına kendi genel anahtarlarını eklemek yaygın yöntemlerdir.

Bölüm 3: Güvenlik Operasyonları ve Savunma Teknolojileri

Etkili bir savunma, ağdaki tüm faaliyetleri görebilmeyi, analiz edebilmeyi ve bunlara müdahale edebilmeyi gerektirir.

Savunmanın Temeli: Ağ Görünürlüğü

Siber güvenlikte temel ilke şudur: "Savunamayacağınızı göremezsiniz." Bu görünürlük iki ana log kaynağından elde edilir:

- **Host-Merkezli Günlükler:** Uç noktalarda (sunucular, iş istasyonları) meydana gelen olayları kaydeder (örn: Windows Olay Günlükleri, Sysmon, Linux syslog). Bir sistem üzerindeki doğrudan etkiyi anlamak için kritiktir.

- **Ağ-Merkezli Günlükler:** Cihazlar arasındaki trafiği izleyen ağ cihazları (güvenlik duvarları, IDS/IPS, proxy) tarafından oluşturulur. Yanal hareket, keşif ve veri sızdırma girişimlerini ortaya çıkarabilir.

Güvenlik Operasyon Merkezi (SOC) Teknolojileri

Teknoloji,Açıklama,Örnek Platformlar

SIEM,"Tüm log kaynaklarından gelen verileri merkezi bir konumda toplar, normalleştirir, korelasyon kuralları ile analiz eder ve uyarılar oluşturur. SOC'un beyni olarak kabul edilir.", "Splunk, Elastic (ELK) Stack"

EDR,"Uç nokta seviyesinde gelişmiş tehditleri (dosyasız saldırılar, anormal davranışlar) izler, tespit eder ve analistlere müdahale (host izolasyonu, süreç sonlandırma) imkanı tanır.", "Microsoft Defender, CrowdStrike"

SOAR,"Farklı güvenlik araçlarını (SIEM, EDR, Firewall) tek bir arayüzde birleştirir.

""Playbook"" adı verilen iş akışları ile manuel süreçleri otomatikleştirerek verimliliği artırır.", "Splunk SOAR, Cortex XSOAR"

IDS/IPS,Ağ trafiğini izleyerek bilinen saldırı imzalarını veya normal davranıştan sapmaları (anomaliler) tespit eder. Güvenlik duvarını aşan tehditleri yakalamak için kullanılır., "Snort, Suricata"

NTA Araçları,"Ağ trafiğini derinlemesine analiz etmek için kullanılır. Wireshark derin paket analizi, NetworkMiner ise hızlı genel bakış ve dosya çıkarma için idealdir.", "Wireshark, NetworkMiner"

Tehdit Tespit Yöntemleri

- **İmza Tabanlı Tespit:** Bilinen saldırı kalıplarını (imzaları) bir veritabanıyla eşleştirir. Bilinen tehditleri tespit etmede etkilidir ancak sıfıncı gün (zero-day) saldırılarını yakalayamaz.
- **Anomali Tabanlı Tespit:** Ağın veya sistemin "normal davranış" profilini (baseline) öğrenir ve bu profilden sapmaları tespit eder. Sıfıncı gün saldırılarını tespit edebilir ancak çok sayıda yanlış pozitif (false positive) üretebilir.

Bölüm 4: SOC Analist Operasyonları ve Süreçleri

Teknoloji kadar, bu teknolojileri kullanan insan süreçleri de savunmanın başarısı için kritiktir.

Uyarı Yönetimi ve Önceliklendirme (Triage)

SOC analistlerinin temel görevi, güvenlik sistemlerinin ürettiği uyarıları yönetmektir. Bu süreç, milyonlarca ham log olayından süzülen şüpheli aktivitelerin incelenmesini içerir.

1. **Uyarının Sahiplenilmesi:** Analist, uyarıyı kendine atar ve durumunu "İnceleniyor" olarak değiştirir.
2. **İnceleme:** Analist, teknik bilgisini ve **Çalışma Kitapları (Workbooks)** adı verilen standart prosedür belgelerini kullanarak uyarıyı detaylıca inceler. Bu aşamada etkilenen varlıklar, şüpheli eylem ve çevredeki olaylar analiz edilir.
3. **Karar ve Raporlama:** İnceleme sonucunda uyarının bir **Gerçek Pozitif (True Positive)** mi yoksa **Yanlış Pozitif (False Positive)** mi olduğuna karar verilir. Bulgular, "Beş N Kuralı" (Kim, Ne, Ne Zaman, Nerede, Neden) temel alınarak raporlanır.
4. **Yükseltme (Escalation):** Gerçek pozitif bir uyarı, derinlemesine analiz veya müdahale gerektiriyorsa, Seviye 2 (L2) analistlerine yükseltilir.

Performans Metrikleri ve SLA'lar

SOC ekibinin verimliliği, belirli metriklerle ölçülür ve genellikle Hizmet Seviyesi Anlaşmaları (SLA) ile tanımlanır.

- **MTTD (Ortalama Tespit Süresi):** Bir tehdidin tespit edilmesi için geçen ortalama süre.
- **MTTR (Ortalama Müdahale Süresi):** Bir tehdide müdahale edilmesi (örn: bir cihazı izole etmek) için geçen ortalama süre.
- **Yanlış Pozitif Oranı:** Yüksek bir oran (%80+), tespit kurallarının zayıf olduğunu ve analistlerin dikkatini dağıttığını gösterir.
- **Uyarı Yükseltme Oranı:** L1 analistlerinin ne kadar bağımsız çalıştığını gösterir. İdeal olarak %50'nin altında olması hedeflenir.

Bölüm 5: Platforma Özgü Tehditler ve Savunmalar

Farklı işletim sistemleri ve platformlar, kendilerine özgü güvenlik riskleri ve savunma stratejileri gerektirir.

Windows Güvenliği

- **RDP Riskleri:** İnternete asla doğrudan açılmamalı, erişim her zaman bir VPN arkasından sağlanmalıdır.
- **PowerShell İzleme:** Yalnızca süreç oluşturma olaylarını izlemek yetersizdir. PowerShell betik bloğu loglaması ve komut geçmişi gibi daha derinlemesine izleme yöntemleri etkinleştirilmelidir.
- **Dosya Uzantıları:** Kullanıcıları yanıltan invoice.pdf.exe gibi çift uzantılı dosyalara karşı korunmak için Dosya Gezgini'nde "Bilinen dosya türleri için uzantıları gizle" seçeneği devre dışı bırakılmalıdır.
- **USB Saldırıları:** Modern saldırı grupları tarafından hala aktif olarak kullanılan bir vektördür. Fiziksel güvenlik ve kullanıcı eğitimi kritik öneme sahiptir.

Linux Güvenliği

- **Loglama Farklılıkları:** Linux, logları yapılandırılmamış düz metin dosyalarına (/var/log/auth.log, syslog) kaydeder. Varsayılan yapılandırma, proses oluşturma gibi kritik çalışma zamanı aktivitelerini kaydetmez.
- **auditd Aracının Önemi:** Sistem çağrılarını (system calls) izleyerek bu görünürlük boşluğunu doldurur. Saldırganların atlatması neredeyse imkansız olduğu için son derece güvenilir bir veri kaynağıdır.
- **SSH Güvenliği:** Parola tabanlı kimlik doğrulama yerine, daha güvenli olan anahtar tabanlı kimlik doğrulama tercih edilmelidir.

Web Uygulama Güvenliği

- **Saldırı Türleri:**
- **İstemci Tarafı:** Kullanıcının tarayıcısındaki zafiyetleri hedefler (tespiti zordur).
- **Sunucu Tarafı:** Uygulama kodu, web sunucusu veya arka uç sistemlerindeki zafiyetleri hedefler (sunucu loglarında iz bırakır).
- **DDoS:** Hizmetleri erişilemez kılmak için kaynak yoğun (/login, /search) uç noktalara aşırı yük bindirir.
- **Web Shell:** Saldırganların sunucuda uzaktan komut çalıştırmasına olanak tanıyan, genellikle dosya yükleme zafiyetleri aracılığıyla yerleştirilen kötü amaçlı betiklerdir.

- **Savunma Teknolojileri:**
- **WAF (Web Uygulama Güvenlik Duvarı):** Şüpheli HTTP trafiğini filtreler ve bot trafiğini CAPTCHA gibi mekanizmalarla engeller.
- **CDN (İçerik Dağıtım Ağı):** DDoS saldırılarının yükünü dağıtarak hafifletir ve sunucuyu doğrudan maruz kalmaktan korur.

E-posta Güvenliği

E-posta sahteciliğini (spoofing) önlemek ve gelen e-postaların meşruiyetini doğrulamak için üç temel standart kullanılır:

- **SPF (Sender Policy Framework):** Belirli bir alan adı adına hangi IP adreslerinin e-posta göndermeye yetkili olduğunu tanımlar.
- **DKIM (DomainKeys Identified Mail):** E-postanın yetkili bir sunucudan geldiğini ve içeriğinin yolda değiştirilmediğini dijital bir imza ile garanti eder.
- **DMARC (Domain-Based Message Authentication...):** SPF ve DKIM sonuçlarını birleştirerek, kimlik doğrulama kontrollerini geçemeyen e-postalara ne yapılacağına dair bir politika (reddet, karantinaya al) belirler.